Fundamentos de Big Data y Ciencia de Datos

Tema 5. Gobernanza de datos en entornos Big Data

Índice

Esquema

Ideas clave

5.1. Introducción y objetivos

5.2. Definición y objetivos de la gobernanza de datos

5.3. Políticas y estándares de datos

5.4. Roles y responsabilidades en la gobernanza de datos

5.5. Protección de datos y seguridad de la información

5.6. Cumplimiento legal y regulatorio de la RGPD

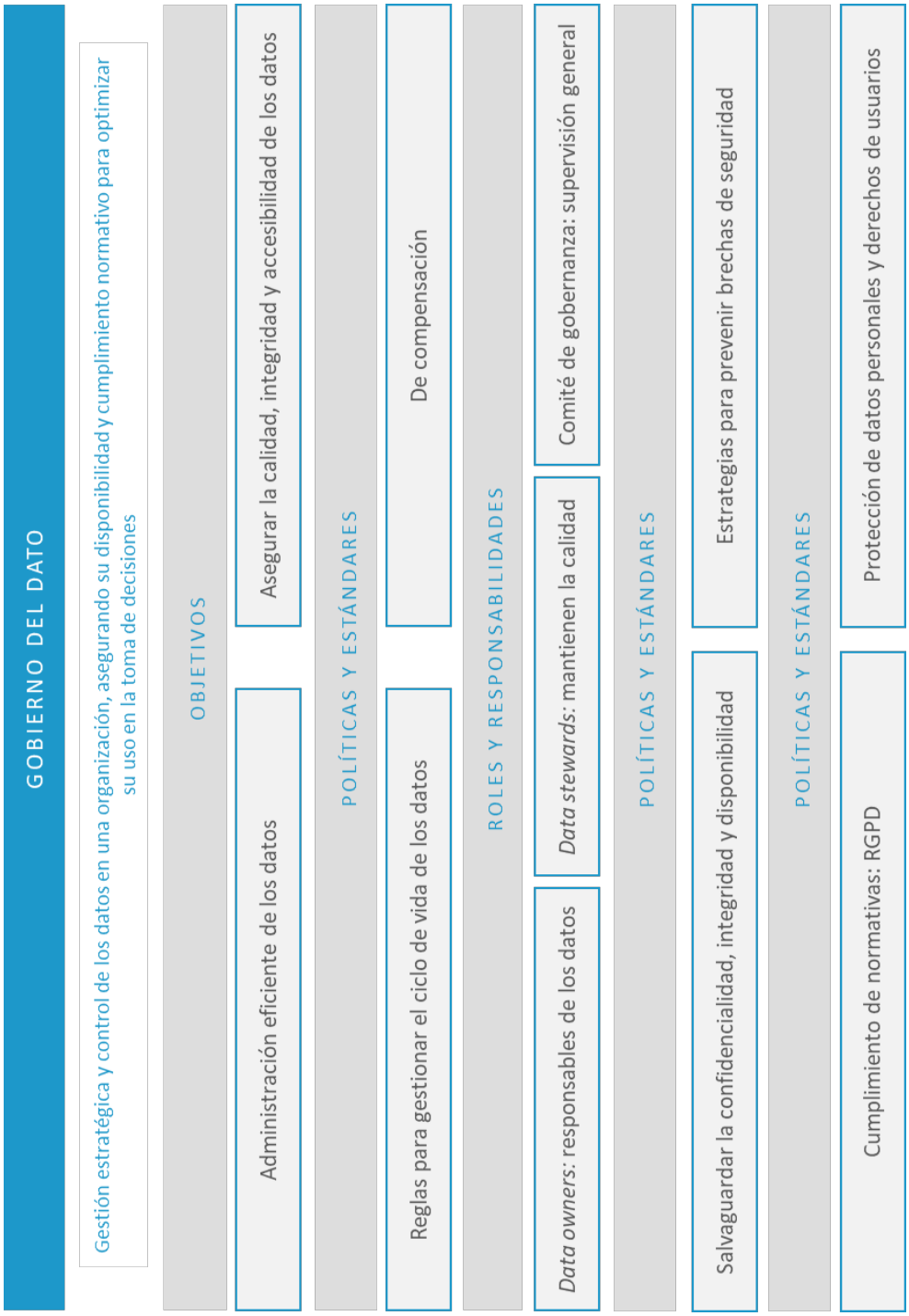
5.7. Referencias bibliográficas

A fondo

La importación del Gobierno del Dato en el framework de DAMA

Agencia Española de Protección de Datos

Esquema



© Universidad Internacional de La Rioja (UNIR)

5.1. Introducción y objetivos

En la era digital actual, el volumen, la velocidad y la variedad de los datos han crecido exponencialmente, lo que ha hecho necesario establecer mecanismos claros y eficientes para gestionar, controlar y proteger estos datos en las organizaciones.

La gobernanza de datos es el conjunto de políticas, roles, estándares y procesos que aseguran la calidad, la integridad, la seguridad y la disponibilidad de los datos.

Esto es aún más crítico en entornos de Big Data, donde los datos provienen de múltiples fuentes (redes sociales, IoT, transacciones financieras, sensores) y su uso inapropiado o ineficaz puede derivar en riesgos operativos, legales o reputacionales.

Este tema proporciona una comprensión de las mejores prácticas y estándares para implementar un programa de gobernanza de datos efectivo en entornos de Big Data, haciendo énfasis en la calidad de los datos, la privacidad, la seguridad y el cumplimiento normativo. Los estudiantes aprenderán a desarrollar políticas de gobernanza, entender los roles clave como el *chief data officer* (CDO) y establecer un marco para el uso ético y responsable de los datos en las organizaciones.

Los objetivos perseguidos en este tema son los siguientes:

- Comprender el **marco teórico** y los conceptos fundamentales de la gobernanza de datos.
- Desarrollar **políticas** de calidad, privacidad y seguridad de datos.
- Definir roles y responsabilidades en un programa de gobernanza de datos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Implementar **estándares internacionales** y marcos normativos en la gobernanza de datos.
- Asegurar el cumplimiento de las **regulaciones** vigentes, como el Reglamento General de Protección de Datos.

© Universidad Internacional de La Rioja (UNIR)

5.2. Definición y objetivos de la gobernanza de datos

La toma de decisiones necesita una fuente de información veraz y confiable que generalmente no existe en las empresas. A principios del siglo XXI, los auditores en Estados Unidos de América prendieron las alarmas porque detectaron una gran manipulación de datos financieros con el fin de mostrar una situación que no correspondía con la realidad (Trejo, 2020). Para evitar la **manipulación de datos,** nace la **gobernanza del dato** y de ella nace a su vez el **gobierno de datos** (GD), el cual se enfoca en la planificación y control de la administración de los datos a un alto nivel.

La meta del gobierno de datos es eliminar **problemas** presentes en las organizaciones: silos de datos, múltiples áreas generando informes manuales, dependencia entre áreas para acceder a datos, organización de informes manualmente, datos duplicados, indicadores clave de rendimiento (KPI) inconsistentes en cuanto a valores y criterios, y cálculos que utilizan diferentes fuentes (Cisterna y Arenas, 2020).

¿Por qué es importante implementar el gobierno de datos?

Facilita la disponibilidad, usabilidad, integridad y seguridad de los datos. Permite manejar un lenguaje común en la organización, mejorar la **accesibilidad** de los datos, asegurar la **calidad e integridad** de los datos y responder a las demandas actuales de ley de protección de datos (Starling, 2015).

© Universidad Internacional de La Rioja (UNIR)

The Global Data Management Community (DAMA International) es una comunidad global sin ánimo de lucro que promueve los conceptos y mejores prácticas de la gestión de información y datos. DAMA International define prácticas bien diferenciadas, como se puede ver en la Figura 1.

Arquitectura	Estructura de datos
Diseño y modelado	Diseño y construcción de aplicaciones para gestionar los datos
Almacenamiento, operación y persistencia	Dónde se va a guardar cada dato y qué operaciones se pueden hacer con cada uno
Seguridad	Estándar, clasificación, administración, autenticación y auditoría de datos
Integración e interoperabilidad	Dónde se producen los datos y cómo se integran
Gestión de datos maestros	De dónde salen los datos, códigos externos e internos, y datos de clientes y de productos
***Data warehousing* e inteligencia de los negocios (BI)**	Arquitectura, implementación, soporte y monitorización
Gestión de los metadatos	Quién ha creado el dato y quién lo ha modificado
Calidad de los datos	Testeo de la integridad de los datos e irrepetibilidad, análisis, medidas y mejoras

Figura 1. Mejores prácticas gobierno de datos. Fuente: basado en DAMA International, 2015.

© Universidad Internacional de La Rioja (UNIR)

En cada una de estas prácticas se puede medir el nivel de madurez con una puntuación que va del cero al cinco, como se explica en la Figura 2.

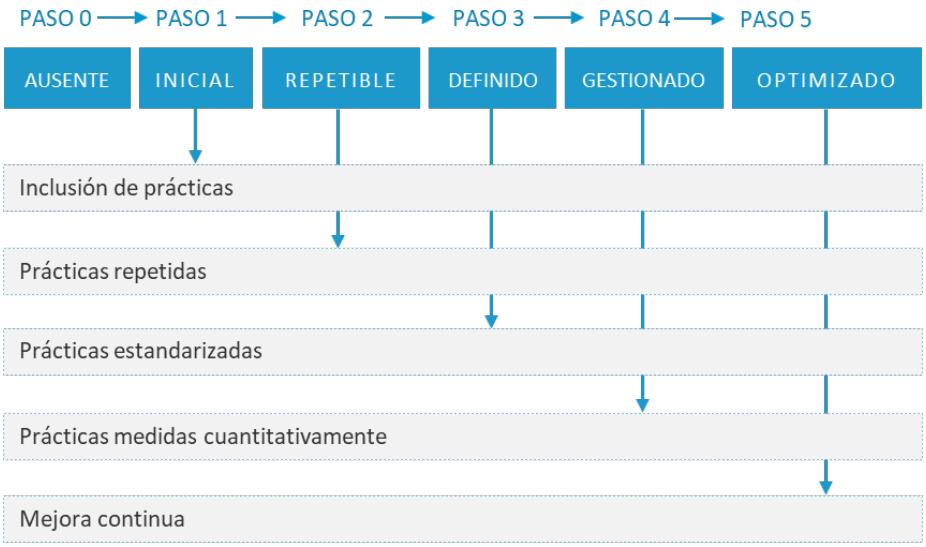


Figura 2. Niveles del modelo de madurez de gobierno de datos. Fuente: basado en Cisterna y Arenas, 2020.

Cisterna y Arenas (2020) y U. S. Government Accountability Office (2020) presentan las siguientes **recomendaciones para empezar a trabajar** en el tema de gobierno de datos:

- Contar con un patrocinador importante dentro de la organización: es muy necesario el **apoyo ejecutivo.**
- Definir el **lugar físico** donde se instalará la oficina de gobierno con un equipo de gobierno conformado.
- Definir qué **pilares estratégicos** apoyarán el gobierno de datos; por lo general estos pilares son las personas, las tecnologías y los procesos.
- Analizar en qué situación se encuentra la organización en cuanto a **madurez** o CMM *(capability madurity model).*

© Universidad Internacional de La Rioja (UNIR)

- Definir el *roadmap* o **ruta a seguir** para la implementación del programa de gobierno.
- Definir **roles internos** de la oficina de gobierno de datos.
- Definir una **política de datos** para la compañía.
- Buscar **aliados** dentro de la organización.

La gobernanza de datos eficaz puede aumentar la disponibilidad y mejorar la calidad de los activos de datos federales. Esto es particularmente importante, ya que las agencias aprovecharon los datos federales para monitorear y medir sus respuestas a la pandemia de la enfermedad del coronavirus (COVID-19).

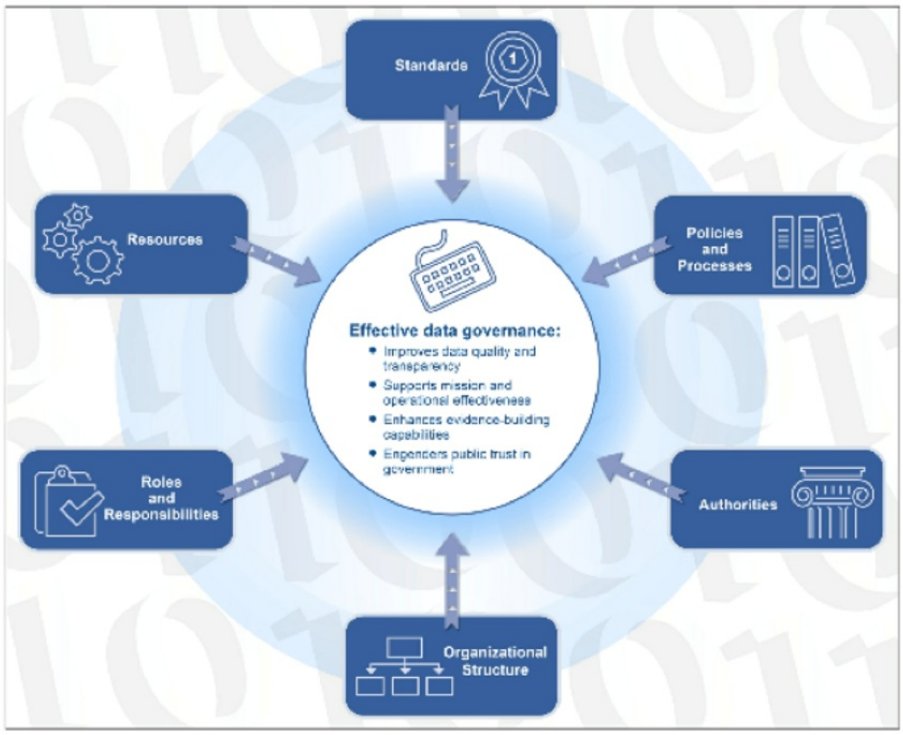
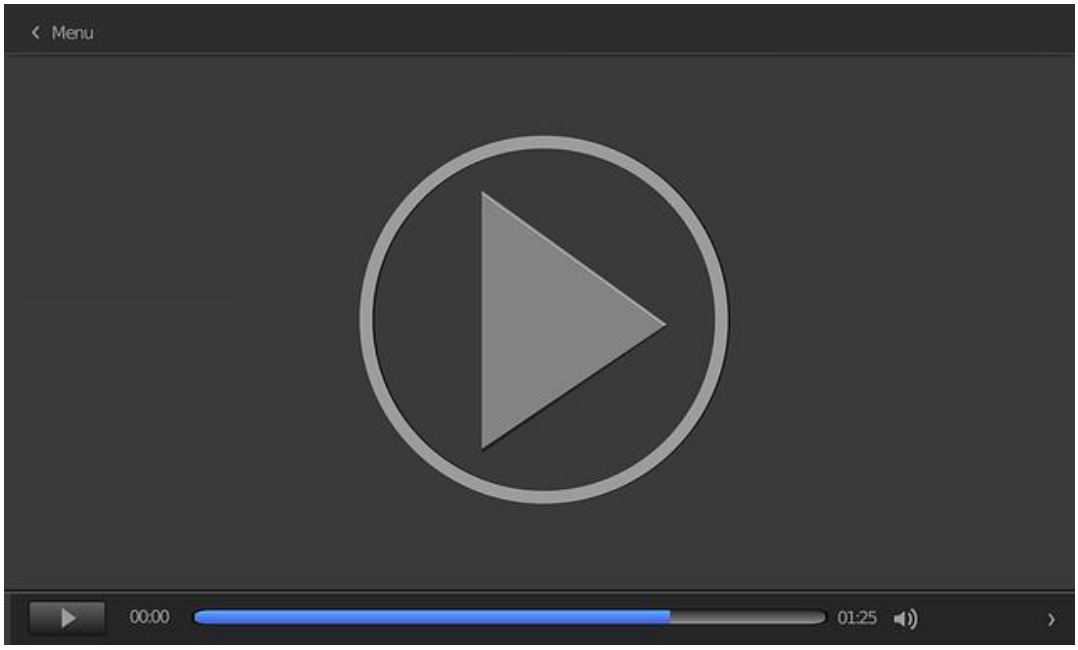


Figura 3. Data governance framework. Fuente: GAO, 2020.

© Universidad Internacional de La Rioja (UNIR)

Por último, accede al vídeo Gobierno del dato en el *framework* DAMA, donde profundizaremos más en el tema.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=ba3df896-5ec4-4adf-8f1d-b23400940d26

© Universidad Internacional de La Rioja (UNIR)

5.3. Políticas y estándares de datos

Políticas de calidad de datos

Estas políticas se enfocan en asegurar que los datos sean precisos, completos, consistentes y relevantes para su uso en el contexto del negocio. En entornos de Big Data, donde los datos pueden provenir de múltiples fuentes (estructurados y no estructurados), es crucial establecer **procesos para validar y verificar la calidad de los datos.**

Componentes:

- Definición de **métricas de calidad** de datos.
- Políticas de corrección de errores y depuración de datos.
- Procedimientos para garantizar la **completitud y consistencia** de los datos.

Ejemplo

Implementación de un proceso automatizado para la detección de datos duplicados o incompletos en sistemas de Big Data.

Políticas de seguridad y privacidad de datos

Estas políticas se centran en la protección de datos contra accesos no autorizados, fugas de información y uso indebido. Con el crecimiento de los volúmenes de datos y el uso de tecnologías avanzadas es fundamental garantizar que se implementen medidas de seguridad adecuadas para proteger los datos sensibles y cumplir con las normativas de privacidad, como el **RGPD** (Reglamento General de Protección de Datos).

© Universidad Internacional de La Rioja (UNIR)

Componentes:

- Control de acceso a los datos (autenticación y autorización).
- Cifrado de datos tanto en tránsito como en reposo.
- Políticas de retención y eliminación segura de datos.
- Cumplimiento con regulaciones internacionales de **privacidad de datos,** como el RGPD (Reglamento (UE) 2016/679) o la Ley de Privacidad del Consumidor de California de 2018 (CC. PA.).

Ejemplo

- Uso de cifrado de extremo a extremo en datos sensibles y acceso restringido basado en roles.

Políticas de gobernanza de metadatos

- La gobernanza de metadatos implica la creación de políticas para gestionar y mantener información estructurada sobre los datos, es decir, los metadatos. Estos incluyen **descripciones de las fuentes de datos, su formato, estructura y propiedad.** Las políticas de gobernanza de metadatos aseguran que los datos sean fácilmente localizables y comprensibles dentro de la organización.

Componentes:

- Estandarización de **nombres, descripciones y formatos** de metadatos.
- Definición de **catálogos de datos** y políticas de etiquetado de datos.
- Mantenimiento de la **trazabilidad** y el **linaje** de los datos.

© Universidad Internacional de La Rioja (UNIR)

Ejemplo

- Implementación de un catálogo de datos centralizado que documente todas las fuentes de datos, su uso y los procesos asociados.

Políticas de retención y archivo de datos

En entornos de Big Data, la acumulación de grandes volúmenes de datos a lo largo del tiempo puede generar **costos operativos y riesgos regulatorios.** Las políticas de retención y archivo de datos aseguran que los datos se almacenen solo durante el tiempo necesario y que los datos obsoletos se eliminen de manera segura y eficiente.

Componentes:

- Establecimiento de **plazos de retención** para diferentes tipos de datos.
- Definición de procedimientos para el **archivo** y la eliminación segura de datos.
- Cumplimiento de **normativas legales** sobre retención de datos.

Ejemplo

- Implementar una política que elimine automáticamente los datos personales después de un período de 7 años, cumpliendo con las regulaciones de privacidad.

Políticas de acceso y control de datos

Estas políticas definen cómo los usuarios pueden acceder y utilizar los datos dentro de la organización. Se establecen **reglas** para garantizar que solo los usuarios autorizados puedan acceder a los datos y que el acceso esté restringido **según la sensibilidad de los datos.**

© Universidad Internacional de La Rioja (UNIR)

Componentes:

- Definición de **roles y permisos** de acceso a los datos.
- Procedimientos de **auditoría** y control del uso de los datos.
- Supervisión y **monitoreo de accesos** a datos críticos.

Ejemplo

- Establecer permisos de acceso diferenciados para empleados de distintas áreas de la empresa (por ejemplo, *marketing* puede acceder a datos de clientes anonimizados, pero no a datos financieros).

Políticas de ética en el uso de datos

Con el uso intensivo de datos, especialmente en proyectos de Big Data e inteligencia artificial, las organizaciones deben establecer políticas que aseguren el uso ético de los datos. Esto incluye **evitar sesgos** en los modelos de datos, respetar la **privacidad** del usuario y garantizar que los datos no se utilicen de manera que puedan causar daño o **discriminación.**

Componentes:

- Directrices para el uso justo y transparente de los datos.
- Procedimientos para evitar el **sesgo algorítmico** y garantizar la **imparcialidad** en la toma de decisiones automatizadas.
- Políticas de responsabilidad ética en el desarrollo de productos basados en datos.

Ejemplo

- Implementar auditorías de sesgo en los modelos de *machine learning* para garantizar que no se discrimine a ciertos grupos de usuarios.

© Universidad Internacional de La Rioja (UNIR)

Cumplimiento con estándares internacionales (ISO, NIST)

Las organizaciones que trabajan con datos, especialmente en entornos globales, deben cumplir con estándares internacionales que guían las mejores prácticas en la gestión, seguridad y uso de datos. Los más reconocidos incluyen la **ISO 27001** para la gestión de la seguridad de la información, y los estándares del **NIST** (National Institute of Standards and Technology) para la seguridad de datos.

© Universidad Internacional de La Rioja (UNIR)

5.4. Roles y responsabilidades en la gobernanza de datos

Para implantar un programa de gobernanza de datos es necesario definir claramente los diversos **roles** y qué papel juegan dentro del **gobierno de datos** (Ladley, 2019). A continuación, veremos los principales roles con sus responsabilidades y ejemplos que nos ayuden a entenderlos mejor.

Chief data officer (CDO)

El *chief data officer* es el ejecutivo responsable de la estrategia general de datos en una organización. Su rol es asegurar que los datos sean un activo estratégico para el negocio, alineando los datos con los objetivos corporativos y garantizando su correcta gobernanza.

Responsabilidades:

- Desarrollar e implementar la **estrategia de datos** de la organización.
- Asegurar el cumplimiento de las **políticas de gobernanza de datos** y regulaciones, como GDPR o CC. PA.
- Supervisar las **iniciativas de calidad, seguridad y uso ético** de los datos.
- Fomentar una **cultura organizacional** centrada en el valor de los datos.

Ejemplo

- Liderar la implementación de un programa de gobierno de datos para asegurar la privacidad y seguridad de los datos de los clientes.

© Universidad Internacional de La Rioja (UNIR)

Data governance council

El **consejo de gobernanza de datos** está compuesto por representantes de varias áreas funcionales de la organización, y su función es **establecer y hacer cumplir las políticas de datos.** Actúa como el grupo de liderazgo que toma decisiones clave sobre la estrategia de datos y su implementación.

Responsabilidades:

- Definir y aprobar las **políticas y estándares de datos** en toda la organización.
- Supervisar el cumplimiento de las regulaciones y asegurar que las políticas se sigan en todas las áreas de negocio.
- Revisar y aprobar **iniciativas de datos** que impactan en el gobierno de datos.
- Resolver **disputas** entre departamentos sobre el acceso o uso de los datos.

Ejemplo

- Decidir sobre la implementación de una política de acceso a datos compartidos entre el departamento de ventas y *marketing* para mejorar la toma de decisiones.

Data steward o administrador de datos

Los *data stewards* son responsables de la **gestión operativa de los datos** en diferentes áreas o dominios específicos de la organización. Aseguran que los datos sean precisos, completos, coherentes y estén disponibles para su uso.

Responsabilidades:

- Mantener la **calidad de los datos** y asegurar que cumplan con las definiciones establecidas en las políticas de gobernanza.
- Coordinar con los propietarios de datos para implementar las **mejores prácticas de gestión de datos.**

© Universidad Internacional de La Rioja (UNIR)

- Proporcionar **soporte técnico** y funcional en el uso de datos a diferentes equipos.
- Monitorear y resolver **problemas de calidad** de los datos en tiempo real.

Ejemplo

- Garantizar que los datos de clientes en un CRM estén actualizados y sean consistentes con otros sistemas internos.

Data owner o propietario de los datos

El *data owner* es el individuo o departamento responsable de la **gestión y control** de un conjunto específico de datos dentro de la organización. Tienen la autoridad para definir cómo se deben usar esos datos y quién puede acceder a ellos.

Responsabilidades:

- Definir las políticas de acceso y uso para los datos bajo su control.
- Asegurar el cumplimiento de las **normas de calidad y seguridad** para los datos que gestionan.
- Proporcionar directrices claras sobre el **uso ético** de los datos.
- Colaborar con el *data steward* para resolver problemas relacionados con los datos.

Ejemplo

- Un director del departamento de recursos humanos podría ser el propietario de los datos de empleados y definir políticas sobre quién puede acceder a esta información.

© Universidad Internacional de La Rioja (UNIR)

Data custodian o custodio de datos

El custodio de datos es responsable de la **gestión técnica** de los datos. Trabajan en estrecha colaboración con los equipos de tecnologías de la información para garantizar que los datos estén almacenados de forma segura, accesibles y que se gestionen adecuadamente desde un punto de vista técnico.

Responsabilidades:

- Gestionar la **infraestructura técnica** que soporta el almacenamiento, acceso y seguridad de los datos.
- Implementar controles técnicos como **el cifrado, la seguridad de acceso** y las copias de seguridad.
- Coordinar con los *data owners* y *data stewards* para asegurar que los requisitos técnicos se cumplan.
- Monitorear **la disponibilidad y el rendimiento** de los sistemas de datos.

Ejemplo

- Asegurarse que los datos financieros estén cifrados tanto en tránsito como en reposo, siguiendo las normativas de la organización.

Data architect o arquitecto de datos

El arquitecto de datos es responsable de diseñar la **arquitectura de datos** que soporta los objetivos estratégicos de la organización. Diseñan los **modelos** de datos y aseguran que los datos fluyan correctamente entre los sistemas y aplicaciones.

© Universidad Internacional de La Rioja (UNIR)

Responsabilidades:

- Diseñar y desarrollar los **modelos de datos** y las bases de datos para soportar la estrategia de datos de la empresa.
- Asegurar la **interoperabilidad** entre los sistemas de datos y que los datos fluyan de manera eficiente.
- Colaborar con *data stewards* y *data custodians* para implementar soluciones de almacenamiento y procesamiento.
- Evaluar y seleccionar **tecnologías** de Big Data y almacenamiento.

Ejemplo

- Diseñar una arquitectura de datos para integrar datos de múltiples fuentes en un *data lake* accesible para los equipos de análisis de la empresa.

© Universidad Internacional de La Rioja (UNIR)

5.5. Protección de datos y seguridad de la información

Todo tratamiento de datos personales ha de cumplir con los principios de la protección de datos establecidos en la legislación en protección de datos personales vigentes y analíticas Big Data. Si trata datos de carácter personal, no es una excepción.

Concepto de dato personal identificado o identificable

Revisemos rápidamente el concepto de dato de carácter personal. En el Reglamento General de Protección de Datos, se definen los datos personales como «toda información sobre una persona física identificada o identificable ("el interesado")» (art. 4.1, Reglamento (UE) 2016/679).

Y se considerará persona física identificable:

> «toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona» (art. 4.1, Reglamento (UE) 2016/679).

No es una definición que esté lejos de la que nos facilitaba la Directiva 95/46/CE, pero sí es actualizada, debido a la relevancia de los avances en los últimos años, como es la consideración de la identidad genética en el concepto de identificable.

Dato personal: cualquier información concerniente a las personas físicas identificadas y/o identificables, tanto relativo a su identidad (nombre y apellidos, domicilio, filiación, NIF…), así como relativo a su existencia y ocupaciones (trabajo, estudios, enfermedades, actividades de ocio, etc.)

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Es fácil encontrar un consenso a la hora de determinar qué información hace que las personas físicas sean identificadas en el marco de las legislaciones de la Unión Europea. Ahora bien, la cuestión no resulta tan trivial si nos preguntamos qué información concreta hace a una persona identificable. Pregunta cuya respuesta no siempre se resuelve de manera uniforme.

Ejemplos de este carácter interpretativo amplio lo tenemos en la consideración de la dirección **IP como dato personal.** La Agencia Española de Protección de Datos lo considera como dato de carácter personal al hacer identificables a las personas, mientras que en Francia ya son dos las sentencias que restaría ese carácter identificable de la IP. Lejos de pretender abundar en los argumentos de un caso concreto, que no pretende más que mostrarse como ejemplo, sí debemos resaltar aquello en lo que existe cierta unanimidad: la particularidad de cada caso.

No obstante, el devenir interpretativo viene marcado claramente por la **jurisprudencia europea,** y tras más de veinte años de directiva europea, han existido adaptaciones o correcciones interpretativas al hilo de las sentencias de los tribunales y, en especial, del Tribunal de Justicia Europeo.

Hoy estaríamos considerando la IP como dato de carácter personal, incluso las IP dinámicas.

El considerando 26 del RGPD establece que **para determinar si una persona es identificable** deberán tenerse en cuenta todos los medios que puedan ser utilizados por el responsable de tratamiento o cualquier otra persona para identificar directa o indirectamente a un individuo y estos medios deben estar objetivamente al alcance. Para ello se deberían tener en consideración los costes asociados, la cantidad de tiempo necesaria, la tecnología disponible y el desarrollo tecnológico. Es decir, no tendrá dicha consideración si son requeridos medios desproporcionados para proceder a la identificación de los individuos.

© Universidad Internacional de La Rioja (UNIR)

Retos de aplicación de la protección de datos en Big Data

Consentimiento del afectado: el principio de responsabilidad proactiva exige al responsable de tratamiento la prueba de la legalidad de este, y uno de los mecanismos establecidos para la legitimación (art 6., Reglamento (UE) 2016/679) es el consentimiento por parte del afectado, siendo el responsable el que debe probar que efectivamente dispone del consentimiento del afectado y que este otorgó respetando los términos establecidos en el reglamento (art. 7, Reglamento (UE) 2016/679).

El consentimiento debe ser concreto, para una finalidad específicamente informada, conforme al principio de finalidad, no pudiéndose tratar los datos para otros fines.

Los usos potenciales para los que se van a utilizar los datos a menudo no pueden ser totalmente identificados en la fase de captación de datos de usuarios, por ejemplo. Esto podría implicar que los usuarios no hayan sido informados de dichas finalidades y abriría la necesidad de obtener el correspondiente consentimiento para el tratamiento de datos para otras finalidades o que estas tuvieran la consideración de compatibles (art 89., Reglamento (UE) 2016/679) con la finalidad informada al afectado en el proceso de captación de la información (habría que tener la capacidad de prueba) o esté amparado por ley.

Además, en los procesos de analítica pueden aparecer nuevos datos que tengan la consideración de dato personal mediante el enriquecimiento con fuentes externas, que faciliten los procesos de reidentificación de las personas, luego su tratamiento implicaría la legitimación de este.

© Universidad Internacional de La Rioja (UNIR)

Interés legítimo como base legal del tratamiento en lugar del consentimiento

Es de resaltar que **confiar en la legitimación con base en intereses legítimos no es una opción flexible,** que no permite cualquier cosa. Las organizaciones de Big Data siempre deben equilibrar sus propios intereses con los de las personas involucradas.

Hay que resaltar que no es posible recurrir al interés legítimo cuando dichos intereses sean anulados por los intereses o derechos y libertades fundamentales del interesado que requieren protección de datos personales, en particular, cuando el sujeto de datos es un niño. Esto lleva a la necesidad de:

- **Ponderación de intereses:** evaluar, previamente a su aplicación, los intereses de la organización frente a los intereses de los individuos.
- **Asunción de responsabilidad:** poder justificar que efectivamente existe un verdadero interés legítimo que, adecuadamente ponderado, no menoscaba los intereses de los afectados.
- **Informar:** la base del tratamiento en el interés legítimo no exime de informar al afectado.

Como sabemos, la **seguridad** es uno de los principios fundamentales de la protección de datos personales, y así se contempla en el RGPD.

Los datos serán:

> «tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas ("integridad y confidencialidad")» (art. 5.1, Reglamento (UE) 2016/679).

© Universidad Internacional de La Rioja (UNIR)

Objetivos alineados con la definición de la seguridad de la información que hacen los principales estándares de la materia, la **seguridad de la información:** preservación de la confidencialidad, integridad y disponibilidad de la información (ISO/IEC 27000:2018).

Término al que también es habitual asociar otras propiedades como son autenticidad, responsabilidad, *accountabilty,* no repudiación o confiabilidad.

Hay que remarcar que sin seguridad no sería posible garantizar la privacidad de los datos personales ni los derechos y libertades de los ciudadanos.

Ahora bien, la seguridad es un camino en búsqueda de un concepto absoluto, pero imposible de alcanzar, cual paradoja de Zenón.

La seguridad absoluta no existe.

Se abordan los riesgos sobre la disponibilidad, integridad y confidencialidad aplicando medidas técnicas y organizativas, con objeto de mitigarlos, transferirlos o aceptarlos, buscando el equilibrio entre el coste de las medidas y su efecto sobre los riesgos.

Por ello es fundamental entender que la seguridad debe ser un proceso gestionado y continuo, orientado a la mejora continua, un ciclo de Deming, más conocido como **PDCA** (planificar, hacer, verificar y actuar permanentemente), destinado a dotar a los tratamientos de datos de carácter personal del entorno de seguridad adecuado y robusto para minimizar los riesgos sobre las personas.

© Universidad Internacional de La Rioja (UNIR)

El RGPD integra la seguridad dentro de las obligaciones de **responsabilidad proactiva,** tanto de responsables de tratamiento como de encargados de tratamiento. No detalla un conjunto de medidas de seguridad, específicamente establecidas, aunque el reglamento contempla aproximaciones que pueden ayudar a las organizaciones a demostrar su alineamiento con la responsabilidad exigida en el RGPD, como son las certificaciones y los códigos de conducta.

Aunque el RGPD prevé el desarrollo por parte de la autoridad de control de la especificación de medidas concretas de seguridad aplicables a escenarios de riesgo de tratamiento de datos personales específicos.

En España, estos reglamentos fueron una oportunidad para **promover el concepto de seguridad de la información** entre empresas y organizaciones.

De hecho, en el mundo de la mediana y pequeña empresa, donde la concienciación en seguridad era realmente baja, de la mano de las adaptaciones a la normativa en protección de datos personales se fueron incorporando conceptos como el uso de contraseñas, la realización de copias de seguridad, el personal autorizado, etc. Se introducían medidas de seguridad en las organizaciones para dar respuesta a una obligación y se beneficiaban las empresas al incluir dentro del dominio de aplicación de las medidas información vital para las empresas: clientes, recursos humanos, etc. Seguramente, esto fue posible por la concreción de controles y medidas de seguridad.

Buenas prácticas en la seguridad de la información

En estos años se han venido desarrollando formalmente conjuntos de buenas prácticas para la gestión de la seguridad de la información, alcanzando una madurez significativa y cuya aproximación a la seguridad siempre se basa en el riesgo y en la eficacia de los controles de seguridad en su reducción.

© Universidad Internacional de La Rioja (UNIR)

Entre los numerosos marcos existentes, a título informativo tenemos:

- NIST: las normas de seguridad del National Institute of Standars and Technology de EE. UU. Establece las bases de seguridad de las administraciones públicas e integra publicaciones (Barret, 2018).
- Serie ISO/IEC 27000: integra, entre otras, la conocida norma ISO/IEC 27001:2018 (Information technology. Security techniques. Information security management systems. Requirements).
- COBIT 2019: marco de referencia para la gestión integral del gobierno de las tecnologías de la información en las organizaciones que incluye la seguridad de la información, desarrollado por ISACA.
- *Common criteria* (ISO/IEC 15408-1:2022): orientada a la armonización de los requisitos de seguridad de productos de *hardware, software, firmware.*
- Esquema Nacional de Seguridad (ENS): ofrece un marco de seguridad para las administraciones públicas españolas.

© Universidad Internacional de La Rioja (UNIR)

ISO/IEC 27001

Veamos con un poco más de detenimiento la ISO/IEC 27001.

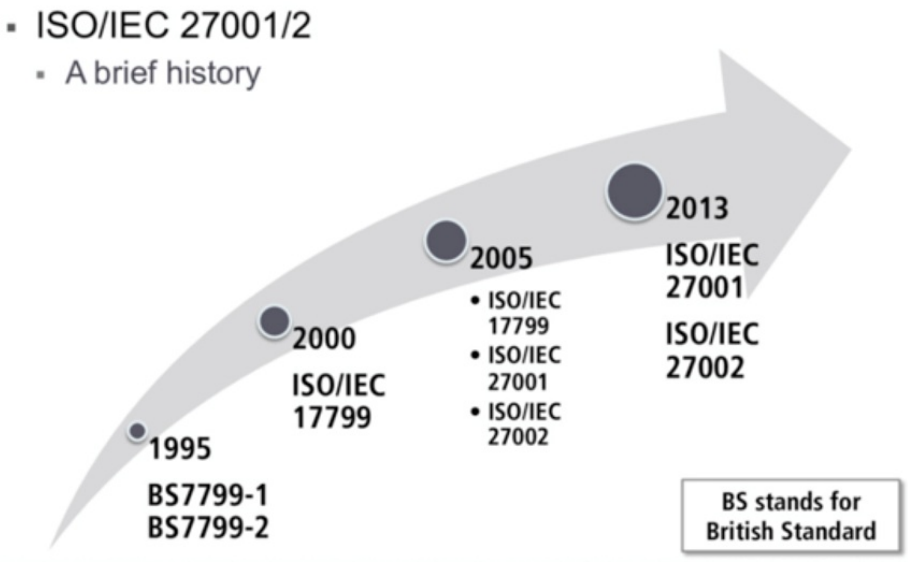


Figura 4. Breve historia ISO/IEC 270001. Fuente: Martins, 2018.

Consolida más de 18 años de trabajo en el desarrollo del estándar cuyos orígenes son desarrollados por British Standard Institution (BSI). Establece el marco de referencia para un sistema de gestión de la seguridad de la información (SGSI) y es certificable IEC/ISO 27001:2018 y la norma ISO/IEC 27002:2022 (Information security, cybersecurity and privacy protection — Information security controls) incorporaba un marco de buenas prácticas de controles de seguridad de la información.

Las dos normas forman parte de la serie ISO/IEC 27000, que desarrolla **controles de seguridad, metodologías de evaluación de riesgos,** etc. Es decir, desarrolla un marco de gestión de la seguridad de la información, que además es certificable.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Para familiarizarnos con los controles de seguridad que habitualmente se deben disponer en las organizaciones para salvaguardar los activos de información, nos introducimos brevemente en la norma de seguridad ISO/IEC 27002.

La ISO/IEC 27002 incorpora catorce dominios de seguridad, sobre los que identifica treinta y cinco objetivos de control de seguridad, con un total de ciento catorce controles de seguridad.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En el siguiente esquema se recogen los dominios de seguridad y los objetivos de control de la norma.

ISO/IEC 27001	
5	Políticas de seguridad de las organizaciones
6	Aspectos organizativos de los sistemas de información
7	Recursos humanos
8	Gestión de activos de información
9	Control de acceso a la información
10	Cifrado
11	Seguridad física y del entorno
12	Seguridad de la operativa
13	Telecomunicaciones
14	Adquisición, desarrollo y mantenimiento de los sistemas de información
15	Suministradores
16	Gestión de incidentes
17	Continuidad de negocio
18	Cumplimiento

Tabla 1. Dominios de seguridad y objetivos de control ISO/IEC 27001. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

5.6. Cumplimiento legal y regulatorio de la RGPD

El RGPD se construye sobre siete principios generales, un conjunto de reglas básicas y de obligado cumplimiento, para el tratamiento de datos de carácter personal. El RGPD consolida y amplía los principios existentes en la legislación europea anterior (Reglamento UE 2016/679).

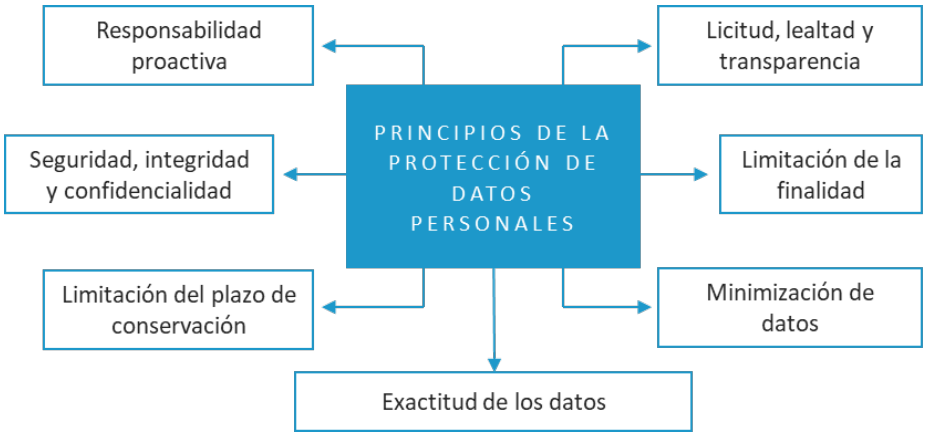


Figura 5. Principios de la protección de datos personales. Fuente: basado en el Reglamento (UE) 2016/679.

Licitud, lealtad y transparencia

Los datos de carácter personal deben ser tratados de manera:

- **Lícita:** de acuerdo con el artículo 6 del Reglamento (UE) 2016/679.
- **Leal:** «fidedigno, verídico y fiel, en el trato o en el desempeño de un oficio o cargo» (RAE, s. f.).
- **Transparente:** de acuerdo con el artículo 12 del Reglamento (UE) 2016/679.

Es decir, **el tratamiento debe ser conforme a la Ley.** Tal y como se establece la legitimidad en el RGPD, debe ser fiel por parte de los responsables de tratamiento frente a los afectados, no debe mediar engaño ni tratar los datos sin lealtad al

© Universidad Internacional de La Rioja (UNIR)

consentimiento obtenido por parte del afectado. Y debe permitir al afectado conocimiento sobre el tratamiento al que están sometidos sus datos personales.

Limitación de la finalidad

Recabados para una **finalidad concreta,** que debe ser **explícita y legítima,** de manera que los datos no podrán ser tratados posteriormente para ninguna otra finalidad, a menos que la nueva finalidad tenga la consideración de compatible, como es el caso del tratamiento de datos para fines posteriores, como son los casos de archivo en interés público, fines de investigación científica e histórica o fines estadísticos.

> «El tratamiento ulterior de los datos personales con fines de archivo en interés público, fines de investigación científica e histórica o fines estadísticos no se considerará incompatible con los fines iniciales ("limitación de la finalidad")» (art. 5.1, de acuerdo con el artículo 6 del Reglamento (UE) 2016/679).

El tratamiento de datos con finalidades históricas, científicas y estadísticas debe **realizarse conforme a las garantías establecidas en el propio RGPD.** El artículo 89 fija, entre otras, la necesidad de incorporar al tratamiento medidas técnicas y organizativas, garantizar el respeto al principio de minimización de los datos personales y aplicar, si es posible, la **pseudonimización:** «garantías y excepciones aplicables al tratamiento con fines de archivo en interés público, fines de investigación científica o histórica o fines estadísticos».

Minimización de datos

Los datos recabados deben ser adecuados, pertinentes y limitados a los estrictamente necesarios para la finalidad prevista para la que son recabados.

Esto implica que **la finalidad ha de justificar los datos que están siendo objeto de tratamiento,** de manera que la misma finalidad no pueda satisfacerse con un conjunto de datos de los afectos menor.

© Universidad Internacional de La Rioja (UNIR)

Exactitud de los datos

Los datos deberán ser exactos y estar **actualizados,** y el responsable de tratamiento debe tomar las medidas necesarias para que los datos que sean inexactos con respecto a los fines del tratamiento se supriman o rectifiquen sin retrasos.

Limitación del plazo de conservación

Los datos personales se mantendrán, permitiendo la identificación de los afectados, por el tiempo estrictamente necesario para los fines del tratamiento. Solo podrán conservarse si se tratan **exclusivamente con fines de archivo en interés público,** fines de **investigación científica o histórica** o fines estadísticos, siempre que sea conforme al artículo 89, apartado 1, del RGPD. En cualquier caso, el responsable de tratamiento debe aplicar las medidas técnicas y organizativas necesarias establecidas en el RGPD para proteger los derechos y libertades del interesado.

Seguridad adecuada, confidencialidad e integridad

Los datos serán tratados de manera que se **garantice** la seguridad adecuada, que debe incluir la protección frente al tratamiento no autorizado o ilícito, su pérdida, destrucción o el daño accidental. Para ello deberá aplicar las medidas técnicas y organizativas apropiadas.

Responsabilidad proactiva

El responsable del tratamiento debe velar en todo momento por la **licitud, lealtad y trasparencia** del tratamiento y el cumplimiento de los principios establecidos.

Ámbito de aplicación de la RGDP

El ámbito de aplicación de la legislación no diferencia los sistemas de tratamiento utilizados en el tratamiento de datos de carácter personal. Pero no se aplica a todos los tratamientos de datos de carácter personal, existen **exclusiones.** Tampoco se aplicará en los tratamientos con fines de **prevención, investigación, detección o enjuiciamiento de infracciones penales,** o de ejecución de sanciones penales,

© Universidad Internacional de La Rioja (UNIR)

incluida la de protección frente a amenazas a la seguridad pública y su prevención (art. 2, Reglamento (UE) 2016/679); así como los derivados de la aplicación del capítulo 2 del título V del TUE (Tratado de la Unión Europea), que aborda las políticas sobre **controles en las fronteras, asilo e inmigración.**

Referente a la aplicación geográfica**, la norma se aplicará a los responsables de tratamiento que se encuadren fuera de la UE** en alguno de los supuestos siguientes (art. 3, Reglamento (UE) 2016/679):

- Si el **tratamiento** se realiza en el contexto de las actividades de un establecimiento del responsable o del encargado en la **Unión Europea,** independientemente de dónde se realiza el tratamiento y dónde reside el afectado, el tratamiento estará sometido al **RGPD** (art. 3.1, Reglamento (UE) 2016/679).

- Si el tratamiento se realiza por parte de responsables de tratamiento residentes **fuera de la UE** que o bien ofrecen **bienes o servicios a residentes europeos** o realizan prácticas de control o seguimiento de su comportamiento (art. 3.2, RGPD). Hay que recordar que en este segundo caso el responsable de tratamiento o el encargado deberá asignar un **representante en la UE,** a menos que sea el tratamiento ocasional y de bajo riesgo para los derechos liberados de los afectados porque, por ejemplo, no afecta a categorías de datos especiales como salud, origen racial, etc. (art. 27, Reglamento (UE) 2016/679).

- Situaciones a las que se añadirán aquellas en las que el derecho de los Estados miembros se aplique en virtud del derecho internacional público como, por ejemplo, las **embajadas.**

De modo que la aplicación del RGPD trasciende el espacio de la UE al establecer como hecho objetivo circunstancias que solo dependen de que el tratamiento se realice sobre ciudadanos residentes en la UE y no sobre la residencia del responsable de tratamiento o encargado de este.

© Universidad Internacional de La Rioja (UNIR)

Extiende el ámbito de aplicación territorial a entidades no radicadas en la UE con actividades que se centren en la oferta de bienes o servicios dirigidas a ciudadanos residentes en la Unión Europea o al seguimiento de estos. Por ejemplo, páginas web de noticias, de venta de servicios o productos dirigidos al espacio de la UE.

Veamos un esquema de decisión sobre cuándo el responsable de tratamiento debe quedar regulado por el Reglamento General de Protección de Datos.

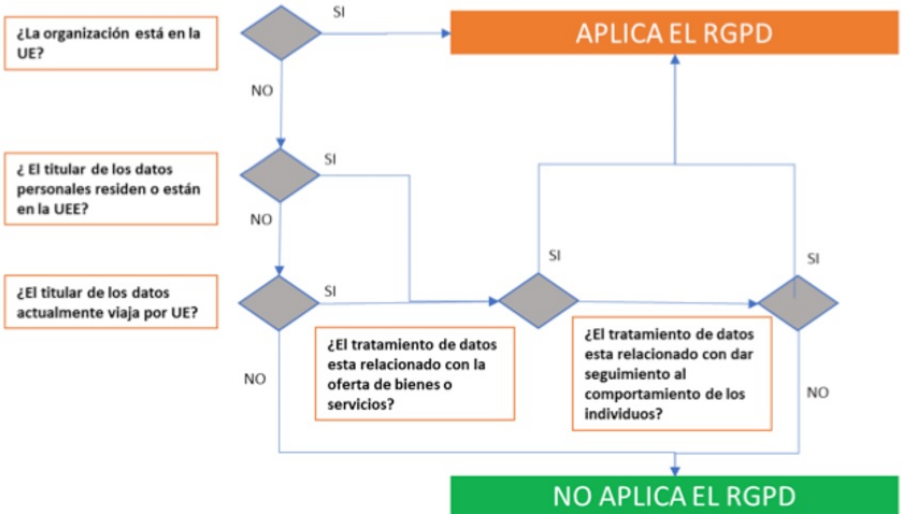


Figura 6. Diagrama de flujo para aplicar RGPD. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

5.7. Referencias bibliográficas

Ladley, J. (2019), Data Governance: How to Design, Deploy and Sustain an Effective Data Governance Program. Morgan Kaufmann.

Barret, M. (2018, abril 16). *Framework for Improving Critical Infrastructure Cybersecurity* (ver. 1.1). National Institute of Standards and Technology. https://www.nist.gov/cyberframework

Cisterna, D., y Arenas, K. [Club Data Governance Office Latam]. (2020, abril 6). *Resumen Webinar: Primeros pasos del Data Governance: Conformando una Oficina de Gobierno de Datos* [Vídeo]. Youtube. https://www.youtube.com/watch?v=DI21Z9yuCOY

DAMA International. (2015). *DAMA-DMBOOK: Guía del conocimiento para la gestión de datos.* Technics Publications.

Directiva 95/46/CE del Parlamento Europeo y del Consejo, de 24 de octubre de 1995, relativa a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos. *Diario Oficial, L 281,* de 23 de noviembre de 1995, p. 31-50. http://data.europa.eu/eli/dir/1995/46/oj

International Organization for Standardization. (2018). *Information technology — Security techniques — Information security management systems — Overview and vocabulary* (estándar ISO/IEC 27000:2018). https://www.iso.org/standard/73906.html

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security controls* (estándar ISO/IEC 27002:2022). https://www.iso.org/standard/75652.html

© Universidad Internacional de La Rioja (UNIR)

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection—Evaluation criteria for IT security* (estándar ISO 15408-1:2022). https://www.iso.org/standard/72891.html

ISACA. (s. f.). *COBIT: an ISACA Framework.* https://www.isaca.org/resources/cobit#2

Martins, M. (2018, enero 20). *Information Security Strategic Management.* Speaker Deck. https://speakerdeck.com/mmartins000/information-security-strategic-management

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, del 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos) [Documento 32016R0679]. *Diario Oficial de la Unión Europea, L 119,* 4 de mayo de 2016. http://data.europa.eu/eli/reg/2016/679/oj

Starling, H. (2015). *Data governance simplified: creating and measuring trusted data for businesses.* CreateSpace Independent Publishing Platform.

Trejo Medina, D. (2020). *Gobierno de datos para directores: Realizando la transformación digital a partir de los datos.* DIDAC.

U. S. Government Accountability Office. (2020, diciembre 16). *Data Governance: Agencies Made Progress in Establishing Governance, but Need to Address Key Milestones* [GAO-21-152]. https://www.gao.gov/products/gao-21-152

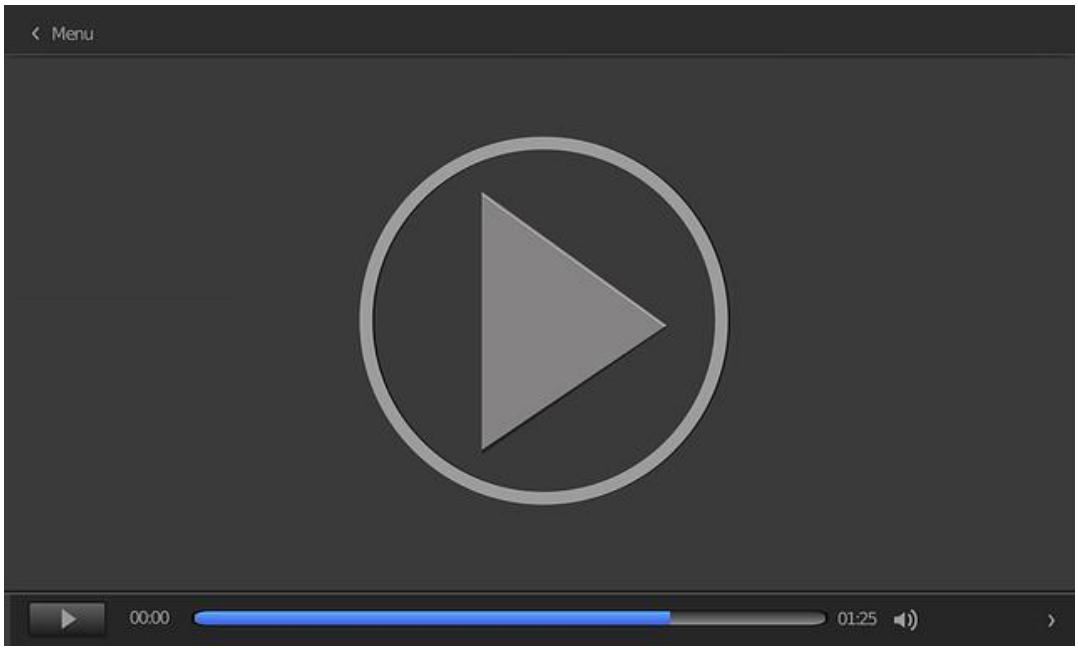
Versión Consolidada del Tratado de la Unión Europea. *Diario Oficial de la Unión Europea*, del 30 de marzo de 2010, p. 83/15-45. https://www.boe.es/doue/2010/083/Z00013-00046.pdf

© Universidad Internacional de La Rioja (UNIR)

La importación del Gobierno del Dato en el framework de DAMA

Anjana Data. (2020, mayo 25). *[Webinar] La importancia del Gobierno del Dato en el framework de DAMA* [Vídeo]. YouTube. https://www.youtube.com/watch?v=5x4_ganTsJY

Michele Iurillo, miembro de la Junta Directiva de DAMA España y Fundador de Synergo, nos comenta la metodología de DAMA y su framework para el Data Management.



Accede al vídeo:

https://www.youtube.com/embed/5x4_ganTsJY

© Universidad Internacional de La Rioja (UNIR)

Agencia Española de Protección de Datos

Agencia Española de Protección de Datos. (2024, julio 16). *Ejerce tus derechos.* https://www.aepd.es/derechos-y-deberes/ejerce-tus-derechos

Encontrarás preguntas frecuentes, documentación de soporte e información sobre procedimientos sancionadores, como, por ejemplo, los derechos que tenemos los ciudadanos en tema de protección de datos.

© Universidad Internacional de La Rioja (UNIR)